

Vergabeakte

Vergabeunterlagen: Leistungsbeschreibung SOC + ISB-Beratung

Vorhaben: SOC Managed Service und ISB-Beratung

Vergabeunterlagen: Leistungsbeschreibung SOC + ISB-Beratung

Aktenzeichen: 3 VK 4/26 Vorhabenbezeichnung: LH-SN-Cyber-SOC-NSV-2026 Dokument-Typ:
Leistungsbeschreibung (Teil A der Vergabeunterlagen) Version: 1.0 vom 27.02.2026 Vergabestelle:
Landeshauptstadt Schwerin / Eigenbetrieb SDS

Teil A: Leistungsbeschreibung

1. Ausgangslage und Bedarfsbegründung

Die Nahverkehr Schwerin GmbH (NSV) betreibt als KRITIS-Betreiber im Sektor Verkehr das städtische Nahverkehrsnetz der Landeshauptstadt Schwerin. Die NSV unterhält eine heterogene IT/OT-Infrastruktur, bestehend aus:

- Leitstelle für Fahrzeugflottensysteme (OT-Systeme)
- Fahrgastinformationssysteme (digitale Anzeigen, App-Backend)
- Ticketing-Systeme und Kasseninfrastruktur
- Enterprise-IT (Active Directory, Exchange, ERP SAP S/4HANA)
- Videoüberwachungsinfrastruktur Haltestellen (ca. 180 Kameras)

Die Akte unterstellt, dass die NSV Betreiberin kritischer Anlagen ist. Nach §§ 30 und 31 BSIG muss sie angemessene Risikomanagementmaßnahmen und funktionsfähige Systeme zur Angriffserkennung sicherstellen. Nachweise nach § 39 BSIG sind nach aktuellem Recht grundsätzlich innerhalb eines Dreijahreszyklus zu führen; der konkrete Nachweistermin wird aus BSI-Bescheid und letztem Prüfabschluss ermittelt. Der Auditbericht vom November 2024 dokumentiert Lücken im Security Operations und Incident Detection.

Das deutsche NIS2-Umsetzungsgesetz ist seit 06.12.2025 in Kraft. Ob die NSV als wichtige oder besonders wichtige Einrichtung beziehungsweise als Betreiberin kritischer Anlagen einzuordnen ist, wird anhand der §§ 28 und 29 BSIG und der aktuellen Schwellenwerte belegt; die Leistungsanforderungen dürfen diese Statusprüfung nicht vorwegnehmen.

2. Leistungsumfang

2.1 Los 1 - Cybersecurity-Operations-Center (SOC) als Managed Service

2.1.1 SIEM-Betrieb

Der Auftragnehmer betreibt ein Security Information and Event Management (SIEM) für die IT/OT-Infrastruktur der NSV. Mindestanforderungen:

- Echtzeit-Korrelation sicherheitsrelevanter Ereignisse aus mind. folgenden Quellen:

- Active Directory / Azure AD (Authentifizierungsereignisse) - Firewalls und Next-Generation-Firewalls - Endpoint Detection & Response (EDR) der NSV - OT-Netzwerk (passives Monitoring, keine aktiven Scans im OT-Bereich) - Syslog-Schnittstellen Server-Infrastruktur

- Datenhaltung Ereignisprotokolle: mind. 12 Monate online, mind. 36 Monate Archiv
- Datenschutzkonformität: Verarbeitung ausschließlich in ISO 27001-zertifizierten Rechenzentren in der EU; Auftragsverarbeitungsvertrag gem. Art. 28 DSGVO

2.1.2 Threat Intelligence

- Abonnement mindestens eines anerkannten Threat-Intelligence-Feeds (MITRE ATT&CK, strukturiert)
- Sektor-spezifische Threat Intelligence für KRITIS Verkehr (z.B. CISA ICS-CERT Advisories, BSI-Warmmeldungen)
- Monatliche Threat-Intelligence-Berichte an NSV-IT-Leitung

2.1.3 Incident Detection und Response

- 24/7/365-Überwachung durch SOC-Analysten (L1/L2/L3)
- Reaktionszeiten:
 - Kritischer Sicherheitsvorfall (Severity 1): Erstreaktion binnen 15 Minuten - Schwerwiegender Vorfall (Severity 2): Erstreaktion binnen 1 Stunde - Mittlerer Vorfall (Severity 3): Reaktion binnen 4 Stunden (Werktag) / 8 Stunden (Wochenende)
- Einleitung forensischer Erstmaßnahmen (Isolation, Sicherung volatiler Daten) auf Abruf
- Unterstützung des abgestuften BSI-Meldeprozesses nach § 32 BSIG (Erstinformation, Faktenblatt, Folgemeldung und Abschlussbericht)

2.1.4 Vulnerability Management

- Monatliche Schwachstellenscans IT-Infrastruktur (authentifiziert)
- Halbjährliche Schwachstellenscans OT-Infrastruktur (passiv/nicht-invasiv)
- CVSS-basierte Priorisierung, Patchmanagement-Empfehlungen
- Quartalsbericht Vulnerability Status an IT-Leitung NSV

2.1.5 Berichtspflichten und SLA

- Monatlicher SOC-Bericht (Executive Summary + technisches Detail)
- Jährlicher Sicherheitslagebericht für NSV-Geschäftsführung
- SLA-Monitoring und Nachweis Einhaltung Reaktionszeiten (maschinell auswertbar)

2.2 Los 2 - BSI-IT-Sicherheitsbeauftragten-Beratung

2.2.1 Funktion ISB

Der Auftragnehmer stellt einen qualifizierten ISB (mindestens BSI-Grundschutz-Praktiker, CISM oder gleichwertiger Nachweis) zur Unterstützung der Betreiberpflichten aus §§ 30 und 31 BSIG bereit. Aufgaben:

- Koordination und Vorbereitung des BSI-Nachweisverfahrens nach § 39 BSIG einschließlich fallbezogener Terminermittlung
- Pflege des ISMS nach ISO 27001 (Dokumentation, interne Audits)
- Beratung Geschäftsführung zu IT-Sicherheitsstrategien
- Teilnahme an Krisenstab bei Sicherheitsvorfällen Severity 1/2

2.2.2 ISMS-Dokumentation

- Erstellung und Pflege Sicherheitsrichtlinien-Set (mind. 20 Richtlinien nach BSI-Grundschutz-Kompodium)

- Risikoanalyse und Behandlungsplan gem. ISO 27005

2.2.3 Schulungen

- Jährliche Security-Awareness-Schulung (alle Mitarbeiter NSV, ca. 350 Personen)
- Phishing-Simulationen (mind. 2 × jährlich)

3. Technische Rahmenbedingungen

- Anbindung: VPN-Zugang zum NSV-Rechenzentrum (IPSec, mind. 100 Mbit/s)
- Schnittstellen: REST-API für SIEM-Ereignisse, STIX/TAXII für Threat Intelligence
- Sprachliche Anforderungen: Alle Berichte und Kommunikation in deutscher Sprache
- Datenhaltungsort: Deutschland oder EU (kein Drittstaatentransfer ohne explizite Genehmigung)

4. Qualitätssicherung und Audits

- Jährliche externe Audits durch akkreditierte Prüfstelle (BSI-anerkannt)
- Recht des Auftraggebers auf Vor-Ort-Inspektion SOC-Standort mit 5 Werktagen Vorankündigung
- Penetrationstest NSV-Infrastruktur (mind. 1 × jährlich, durch zertifizierte Pentester, OSCP oder gleichwertig)